SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks**.(20 Mark).**

3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.**(10 Marks)**

Code of Conduct:

I Dinesh R-192421117 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: R Dinesh

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures.	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures.
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

Question 1 – OSINT-Based Email Enumeration Using theHarvester (20 Marks)
Question: As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain tesla.com using theHarvester in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses. Categorize email addresses into likely roles, analyze how attackers could use the information, and recommend at least five countermeasures.

1. Aim
To perform Open-Source Intelligence (OSINT) based email enumeration on the domain tesla.com using theHarvester in Kali Linux and identify potential social engineering risks.
2. Introduction
OSINT is the process of collecting information from publicly available sources. TheHarvester is a reconnaissance tool used by security analysts to discover publicly indexed email addresses, subdomains, hostnames, and IP addresses associated with a target domain.
This assessment helps an organization understand what information is publicly exposed and how it could be misused in social engineering attacks.
3. Procedure and Commands
Step 1: Open Kali Linux terminal.
Update the package list and install the tool if required.
sudo apt update
sudo apt install theharvester
Step 2: Check the tool's available options.
theHarvester -h
Step 3: Perform an OSINT search.
Use a supported public search source. For example, where the installed version supports the crtsh source:
theHarvester -d tesla.com -b crtsh
The available data sources and command options may vary by version. Use the help output to select an appropriate source.
Step 4: Collect and analyze the findings.
Record the results returned by the tool, including:

- Publicly indexed email addresses
- Discovered subdomains and hostnames
- IP addresses associated with discovered hosts
- The public source of each finding, where available

Save the terminal output or take screenshots for the report. Do not assume that every discovered hostname is active or that every IP address belongs exclusively to the organization.
4. Categorization of Email Addresses
Publicly discovered email addresses can be classified by likely role based on their names or prefixes.

Email pattern	Likely role	Possible risk
support@...	Customer Support	Fake customer complaints or support impersonation
sales@...	Sales Team	Fraudulent quotations or payment requests
hr@... or careers@...	Human Resources	Fake recruitment messages or employee-data requests
admin@...	Administration	Impersonation of administrative staff
it@... or security@...	Technical Team	Fake IT alerts or password-reset requests

These are examples of common patterns, not verified Tesla email addresses. Actual findings should be entered into the report only when supported by the tool's output.
5. Analysis of Security Risks
a) Spear-phishing attacks
Attackers may use publicly available employee information to prepare targeted emails that appear relevant to a particular department. For example, a fraudulent message may imitate a recruitment process or technical notification.
b) Credential harvesting
An attacker may send a deceptive email directing a user to a fake login page. If the user enters their credentials, the attacker may attempt to access the account.
c) Impersonation attacks

Information about employee roles and organizational naming patterns may help an attacker impersonate support staff, administrators, or other employees.

d) Network reconnaissance

Subdomains, hostnames, and IP addresses can reveal publicly visible services and aspects of an organization's infrastructure. This information may help an attacker identify targets for further investigation.

e) Business impact

Successful attacks can lead to unauthorized access, data leakage, financial fraud, reputational damage, and disruption of business operations.

6. Recommended Countermeasures

1. Reduce information leakage: Review public websites and remove unnecessary exposure of employee contact information and internal infrastructure details.
2. Conduct security awareness training: Teach employees to identify suspicious emails, unexpected attachments, and fraudulent requests.
3. Implement email authentication: Configure SPF, DKIM, and DMARC to help protect against email spoofing.
4. Enable multi-factor authentication: Require MFA to reduce the risk of account compromise from stolen passwords.
5. Use secure email filtering: Detect phishing messages, malicious attachments, and suspicious links.
6. Monitor exposed assets: Regularly review publicly indexed subdomains, hostnames, and other exposed information.
7. Establish verification procedures: Require independent verification of sensitive requests, password resets, and financial transactions.
8. Apply least privilege: Limit employee access to information and systems according to job responsibilities.

7**. Result**

The assessment identifies the types of information that theHarvester can discover through public sources. Insert the actual email addresses, subdomains, hostnames, and IP addresses obtained during your authorized lab exercise. Use these findings to assess information leakage and recommend appropriate security controls.

8. Conclusion

TheHarvester helps security analysts understand an organization's publicly visible digital footprint. Although OSINT information is not necessarily confidential, attackers can combine it to create convincing spear-phishing and impersonation attempts. Regular exposure assessments, employee training, email authentication, and MFA can reduce these risks

Question 2 – Phishing Awareness Simulation Using GoPhish (20 Marks)

Question: Conduct a phishing awareness simulation using GoPhish and dummy employee accounts. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Recommend ways to improve employee awareness.

1. Aim

To conduct an authorized phishing awareness simulation using GoPhish and evaluate employee responses to simulated phishing emails.

2. Introduction

GoPhish is an open-source phishing simulation framework used to test employee awareness and identify weaknesses in an organization's email security. It helps security teams measure how employees respond to simulated phishing messages without conducting a real credential theft attack.

3. Procedure

Step 1: Install and start GoPhish

Download GoPhish from its official project repository and follow the installation instructions for the lab operating system. Start the application using the executable provided.

Step 2: Create dummy employee accounts

Use the dummy email accounts provided in the lab. Do not use real employee credentials or send simulated phishing emails to people without authorization.

Step 3: Create an email template

Create a simulated security-awareness email that resembles a routine IT notification. Use a clearly controlled lab landing page and dummy accounts.
Example email template:
Dear Employee,
Our organization is conducting a security awareness exercise to evaluate how employees identify suspicious emails and links.
Please review the message carefully and follow the instructions provided in the authorized training environment.
Thank you for your cooperation.
IT Security Awareness Team
Step 4: Configure the landing page
Create a harmless training page that explains the warning signs of phishing. Do not collect or store actual passwords. Record only the interaction metrics needed for the exercise.
Step 5: Configure and launch the campaign
In the GoPhish dashboard:

1. Create a sending profile using the authorized lab mail server.
2. Add the dummy employee accounts to a recipient group.
3. Select the email template and training landing page.
4. Configure the campaign name and launch settings.
5. Launch the campaign within the approved lab environment.

Step 6: Monitor campaign interactions
Review the campaign dashboard and record:

- Number of emails sent and delivered
- Number of recipients who opened the email
- Number of recipients who clicked the simulated link
- Number of recipients who completed the training interaction, if measured

Take screenshots of the configuration and results for submission.

4. Report and Analysis

Use the following table to record your actual lab results.

Metric	Calculation
Delivery rate	Delivered emails ÷ Emails sent × 100
Open rate	Unique email opens ÷ Delivered emails × 100
Click rate	Unique link clicks ÷ Delivered emails × 100

Example calculation using hypothetical data: if 100 emails are sent, 90 are delivered, 54 are opened, and 18 recipients click the link:

- Delivery rate = 90/100 × 100 = 90%
- Open rate = 54/90 × 100 = 60%
- Click rate = 18/90 × 100 = 20%

These numbers are illustrative only and are not actual GoPhish results.

5. Security Weaknesses Identified

- High click rate: Employees may not carefully inspect suspicious links.
- High interaction rate: Employees may trust messages without verifying the sender.
- Low reporting rate: Employees may not know how to report suspected phishing.
- Insufficient training: Employees may lack awareness of common social engineering techniques.

Email open rates alone do not prove that an employee was deceived, because email clients may automatically load tracking images.

6. Recommendations

1. Conduct regular phishing awareness training.
2. Teach employees to verify sender addresses and website URLs.
3. Encourage immediate reporting of suspicious emails.
4. Implement SPF, DKIM, and DMARC.
5. Deploy email filtering and malware scanning.
6. Enable multi-factor authentication.
7. Repeat authorized phishing simulations periodically.
8. Provide additional training based on observed weaknesses.

7. Result
The GoPhish campaign measures email delivery, opening, and link-clicking behavior. Enter the actual results from your lab dashboard and use them to identify areas where employees require additional security awareness training.
8. Conclusion
GoPhish provides a controlled method for evaluating employee awareness of phishing attacks. By analyzing delivery, open, and click rates, an organization can identify weaknesses and improve its security training. Combining awareness programs with email security controls and MFA can reduce the risk of successful phishing attacks.

Question 3 – Nmap Aggressive Scan and Social Engineering (10 Marks)
Question: Using Nmap Aggressive Scan (-A) on scanme.nmap.org, gather detailed information about the target, including operating system details, open ports, and service versions. Explain how attackers could use the collected information in a social engineering attack against the IT support team. Prepare a report with the attack methodology and defensive recommendations.

1. Aim
To understand how Nmap aggressive scanning identifies network services and how the collected information could be misused in social engineering attacks.
2. Introduction
Nmap is a network scanning tool used to discover hosts, open ports, running services, and possible operating system details. The -A option enables several advanced detection features, including OS detection, service/version detection, default scripts, and traceroute.
The assessment uses scanme.nmap.org, a host provided by the Nmap project for authorized scanning exercises. Scanning should remain within the target's published usage limits.
3. Procedure and Command
Open the Kali Linux terminal and execute:
nmap -A scanme.nmap.org
This command attempts to identify:

- Open TCP ports
- Running services and their versions
- Operating system information, when detectable
- Results from selected default NSE scripts
- Network route information through traceroute

Save the actual output for the assessment report. Results may vary depending on network conditions and changes to the target.
4. Analysis of Findings

Finding	Security significance
Open ports	Identify network services that may be accessible
Service versions	Help determine whether software may be outdated or vulnerable
OS details	Provide clues about the target's operating environment
Script results	May reveal additional service information or configuration weaknesses
Traceroute	Provides information about the network path to the target

An open port does not automatically mean that a system is vulnerable. Each result must be evaluated in context.
5. Social Engineering Attack Methodology
An attacker could misuse the information obtained from a scan in the following ways.
Step 1: Reconnaissance
The attacker collects publicly available technical information about the target, including services and software versions.
Step 2: Target selection

The attacker uses the findings to understand the likely technical environment and identifies the kinds of responsibilities that an IT support team may handle.

Step 3: Impersonation attempt

The attacker may impersonate a technical support representative or claim to be contacting the organization about a software update or security issue.

Step 4: Deceptive request

The attacker may attempt to persuade an employee to disclose credentials, approve an unauthorized access request, or install an unapproved application.

Step 5: Potential impact

If the employee trusts the fraudulent request, the attacker may gain unauthorized access, compromise accounts, or expose confidential information.

These steps describe a potential threat scenario, not evidence that an attack has occurred against the target.

6. Defensive Recommendations

1. Employee awareness: Train IT support staff to recognize impersonation and suspicious requests.
2. Identity verification: Verify the identity of callers and requesters through approved channels.
3. MFA: Require multi-factor authentication for important accounts.
4. Access control: Apply least-privilege permissions and restrict administrative access.
5. Patch management: Regularly update operating systems and exposed services.
6. Network security: Use firewalls to restrict unnecessary ports and services.
7. Incident reporting: Establish a procedure for reporting suspicious calls, emails, and access requests.
8. Regular assessments: Conduct authorized vulnerability assessments and review exposed services.

7. Result

The Nmap -A command is used to gather detailed information about the authorized target. Record the actual open ports, service versions, and OS detection results from your scan. These findings can help assess the information available to a potential attacker and identify appropriate security controls.

8. Conclusion

Nmap aggressive scanning supports network reconnaissance by identifying exposed services and collecting technical details. Attackers may combine such information with social engineering to create convincing fraudulent requests. Organizations can reduce these risks through employee training, strong identity verification, access restrictions, regular patching, and network monitoring.